

Engenharia de Segurança da Informação (PARTE 2)

Engenharia de Qualidade e Confiabilidade

Prof. Me. Sergio Souza Novak — UniRV

16 de abril de 2026



1 Introdução à Criptografia

- Conceitos e Funcionamento
- Tipos de Criptografia
- Algoritmos Comuns
- Aplicação e Benefícios

2 Controles e Atributos

- Ciclo de Defesa
- Relação com Atributos e Casos
- Segurança no Ciclo de Vida

3 Segurança e Organizações

- Decisão de Negócio e Políticas
- Gestão de Ativos e Responsabilidades
- Políticas de Acesso e Riscos

4 Requisitos de Segurança

- Definição e Estratégias
- Processo Dirigido por Risco

Introdução à Criptografia

O que é Criptografia?

A criptografia é usada para proteger os dados contra roubo, alteração ou comprometimento.

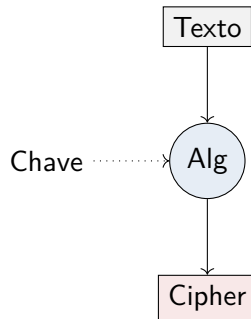
- **Definição:** Processo de transformar dados em um código secreto.
- **Mecanismo:** Só pode ser desbloqueado com uma chave digital exclusiva.
- **Objetivo:** Garantir que apenas partes autorizadas acessem a informação.

Processamento de Dados

Funciona para dados **em repouso** (armazenados), **em trânsito** (rede) ou **em processamento**, seja localmente ou na nuvem.

Como funciona a Criptografia

- **Texto Simples (Plaintext):** A informação original legível.
- **Algoritmo:** Modelo matemático usado para converter os dados.
- **Texto Criptografado (Ciphertext):** A versão embaralhada e ilegível.
- **Chave:** Uma string de números ou senha necessária para decodificar.



A segurança de um método criptográfico depende da complexidade da sua chave.

- **Ataque de Força Bruta:** Tentativa de adivinhar a chave testando todas as combinações possíveis.
- **Resistência:** Métodos modernos usam chaves tão grandes que computadores atuais levariam séculos para quebrá-las.

Segurança baseada em Algoritmos

Matemáticos e cientistas inventam modelos cada vez mais complexos para acompanhar a evolução do poder de processamento.

Exemplo Histórico: Cifra de César

Um dos primeiros exemplos, usado pelo imperador romano Júlio César para mensagens militares.

- **Método:** Criptografia de substituição simples.
- **Lógica:** Cada letra é substituída por outra um número fixo de posições à frente no alfabeto.
- **Chave (Shift):** Se o shift for 4 para a esquerda, cada "E" vira "A".

A B C D E F G ... → X Y Z A B C D ...

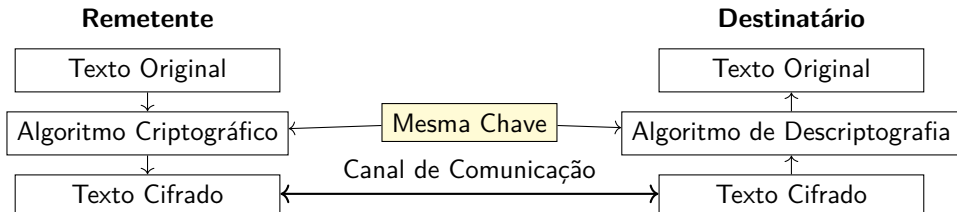
Modernidade

Hoje, as chaves são strings de centenas ou milhares de caracteres gerados por computador.

Criptografia Simétrica

Também conhecida como criptografia de **chave privada** ou chave compartilhada.

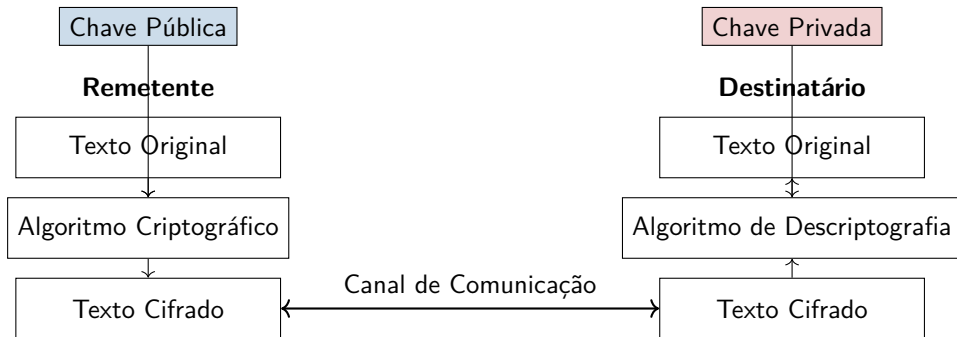
- **Mecanismo:** Usa a **mesma chave** tanto para criptografar quanto para descriptografar.
- **Vantagens:** Mais barata de produzir e processamento extremamente rápido (baixo atraso).
- **Desvantagem:** O desafio de trocar a chave com segurança. Se alguém intercepta a chave, a segurança é totalmente comprometida.



Criptografia Assimétrica

Também conhecida como criptografia de **chave pública**.

- **Mecanismo:** Usa **duas chaves** separadas (um par):
 - **Chave Pública:** Compartilhada com todos (para criptografar).
 - **Chave Privada:** Mantida em segredo pelo dono (para descriptografar).
- **Chaves Típicas:** Entre 1.024 e 2.048 bits.
- **Custo:** Exige muito mais capacidade computacional e tempo de processamento.



- **DES (Data Encryption Standard):** Padrão dos anos 70. Hoje obsoleto devido ao tamanho da chave (56 bits).
- **3DES (Triple DES):** Aplica o DES três vezes. Descontinuado para fins oficiais desde 2023 por ser inseguro.
- **AES (Advanced Encryption Standard):** O padrão mundial hoje. Usa blocos de 128 bits e chaves de até 256 bits. Extremamente seguro e eficiente.
- **Twofish:** Focado em hardware/software, muito rápido e usado em apps como PGP.

- **RSA (Rivest-Shamir-Adelman - 1977):** Baseado na dificuldade de fatorar números primos gigantes. Muito seguro, mas lento. Usado para proteger a troca das chaves simétricas.
- **ECC (Elliptic Curve Cryptography):** Forma avançadamente eficiente. Uma chave ECC de 256 bits oferece segurança similar a uma RSA de 3.072 bits.

Eficiência do ECC

É preferível em dispositivos com hardware limitado (celulares, IoT) por exigir menor infraestrutura e processamento.

Usamos criptografia constantemente, muitas vezes de forma invisível:

- **HTTPS (TLS):** O "s" em sites seguros indica criptografia em trânsito.
- **VPNs:** Criam túneis privados para tráfego de dados.
- **Mensagens:** apps como WhatsApp e e-mails usam criptografia para garantir privacidade.

Conformidade

É obrigatoriedade regulatória em setores como Saúde (dados de pacientes), Bancário e Varejo.

As 4 Funções da Criptografia

1. Confidencialidade: Mantém os dados em segredo.

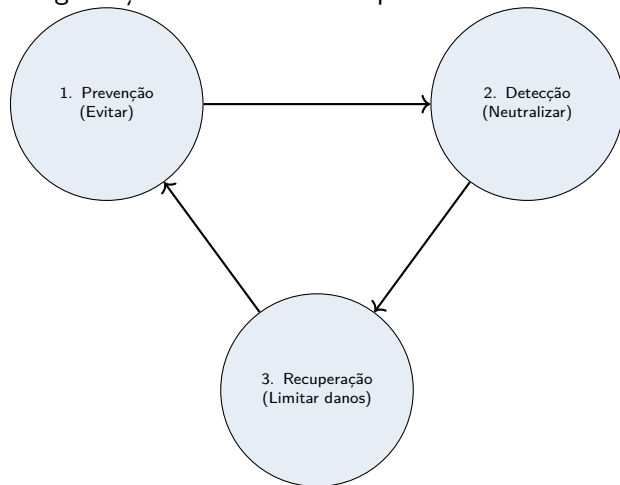
2. Integridade: Verifica se os dados não foram alterados.

3. Autenticação: Valida a origem da mensagem.

4. Não Repúdio: Impede que o remetente negue o envio.

Controles e Atributos

A segurança baseia-se em três pilares fundamentais:



1. Prevenção da Vulnerabilidade

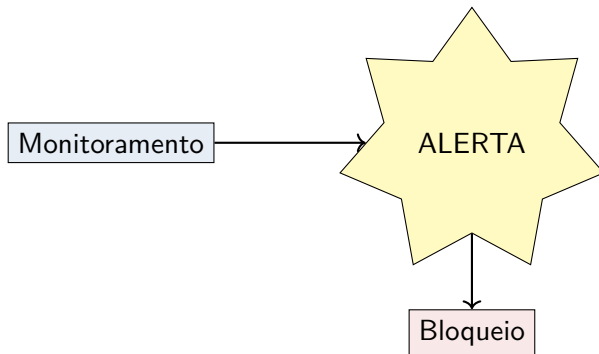
- Estratégia de projetar o sistema para que ataques não logrem êxito.
- **Isolamento:** Sistemas militares sensíveis não conectados à Internet.
- **Encriptação:** Um dos controles mais eficazes.

Custo da Prevenção

Encriptação forte é cara em termos de processamento, mas é uma barreira quase intransponível para o acesso não autorizado a dados.

2. Detecção e Neutralização de Ataques

- Monitoramento constante da operação do sistema.
- Verificação de padrões de atividade incomuns (ex: múltiplas tentativas de login em segundos).
- **Ação corretiva:** Desligar partes do sistema ou restringir o acesso a usuários suspeitos.



3. Limitação da Exposição e Recuperação

Quando a prevenção e a detecção falham, o objetivo é sobreviver ao ataque:

- **Backup Automatizado:** Garantir que os dados possam ser restaurados.
- **Espelhamento (Mirroring):** Manter réplicas da informação em tempo real.
- **Estratégias de Negócio:** Apólices de seguro contra crimes cibernéticos.

Resiliência

A capacidade de retomar a operação normal o mais rápido possível após uma violação.

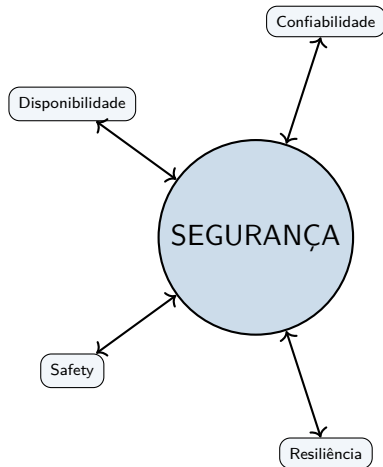
Segurança e Outros Atributos

A segurança não existe isoladamente; ela está intrinsecamente ligada aos demais atributos de dependabilidade:

- Confiabilidade (Reliability)
- Disponibilidade (Availability)
- Segurança (Safety)
- Resiliência (Resilience)

Ideia Central

A segurança atua como um elemento integrador, influenciando diretamente o funcionamento e a robustez do sistema como um todo.



1. Segurança e Confiabilidade

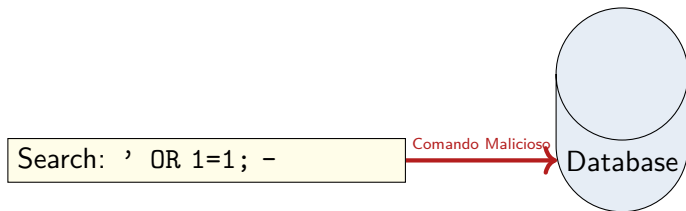
- Ataques que corrompem dados levam a falhas de sistema, reduzindo a confiabilidade.
- **Exploração de Brechas:** Entradas imprevistas ou limites de vetores não verificados.
- **Injeção de Código:** Se o sistema não valida a entrada, o atacante pode executar comandos maliciosos.

Entrada de Dados

A falta de validação rigorosa é uma das maiores causas de vulnerabilidades técnicas.

[CS6] Caso de Estudo: Injeção de Código (SQL)

- **Cenário:** Um campo de busca em um site não sanitiza as entradas.
- **Ataque:** O invasor insere comandos SQL no campo de busca (ex: ' OR 1=1; -).
- **Resultado:** O sistema executa o comando e retorna todos os usuários do banco de dados, ignorando a autenticação.



2. Segurança e Disponibilidade

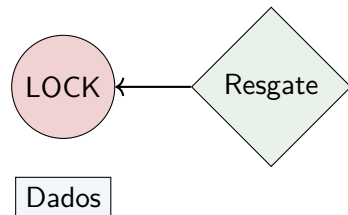
- O foco aqui são os ataques que visam paralisar o serviço.
- **Inundação (Flooding):** Servidores web bombardeados com solicitações de múltiplas fontes.
- **Extorsão:** Ameaça de manter o site offline a menos que um resgate seja pago.

Ransomware e DoS

A disponibilidade é atacada tanto por força bruta quanto por sequestro de ativos.

[CS7] Caso de Estudo: Sequestro de Dados

Ação: Um malware criptografa todos os arquivos críticos de um servidor hospitalar. **Dilema:** O hospital não consegue acessar prontuários. Os atacantes exigem pagamento em criptomoedas para fornecer a chave de descryptografia.



3. Segurança (Security) vs. Segurança (Safety)

- **Safety:** Preocupa-se com acidentes e falhas acidentais.
- **Security:** Preocupa-se com ataques maliciosos e deliberados.
- **Conexão:** Um ataque (Security) pode corromper o código executável, invalidando todas as garantias de Safety do sistema.

Características Negativas

Ambas são sobre o que **não deve acontecer**. Nunca se pode provar que um sistema é 100% seguro sob essas óticas.

4. Segurança e Resiliência

- Resiliência é a capacidade de resistir, reagir e se recuperar de eventos prejudiciais.
- Hoje, a maioria dos eventos prejudiciais são ciberataques.
- **Foco:** Manter as funções críticas do sistema mesmo sob ataque intenso.



- Segurança não é uma funcionalidade "extra".
- Deve ser considerada desde os requisitos iniciais até a operação e manutenção.
- Projeto para segurança → Desenvolvimento seguro → Teste de segurança.

Conclusão

Sistemas confiáveis, disponíveis e robustos exigem que a segurança seja um pilar central de todo o processo de engenharia.

Segurança e Organizações

Criar sistemas seguros é caro e incerto. As organizações enfrentam o desafio de equilibrar custos e proteção.

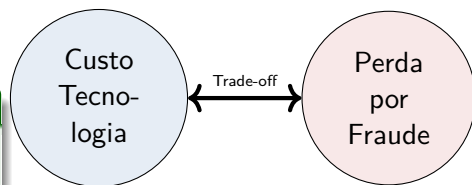
- **Segurança (Safety) vs. Security:**

- *Safety*: Regida por leis e normas rigorosas (custo secundário à vida).
 - *Security*: Decisão muitas vezes pragmática, baseada em risco pessoal/financeiro.
- Frequentemente, sistemas não seguros são implantados porque a lei não os impede (exceto em casos de dados pessoais).

Avaliação de Perdas: As empresas podem decidir que é mais barato aceitar um risco do que investir para eliminá-lo.

Caso das Operadoras de Cartão

Muitas vezes, compensar o usuário por fraudes é mais barato do que implantar novas tecnologias globais de redução de fraudes em tempo integral.



Gerenciamento de Risco: Negócio vs. Técnico

- O gerenciamento de risco é, acima de tudo, uma questão de **negócio**.
- Devem ser pesadas as perdas financeiras e de reputação contra o custo das medidas de proteção.

Política de Segurança

Para um gerenciamento eficaz, a organização deve ter uma política documentada e clara para todos os colaboradores.

Uma política de segurança robusta deve definir quatro pilares:

1. Ativos a serem protegidos

2. Nível de proteção necessário

3. Responsabilidades (Usuário/Gestor/Org)

4. Procedimentos e tecnologias existentes

1. Ativos a serem Protegidos

- Nem todos os ativos justificam segurança rigorosa.
- **Dados Públicos:** Manter seguras informações que já são de domínio público é um custo desnecessário.
- Ativos de valor livre podem até melhorar a imagem da empresa se forem disponibilizados sem barreiras.

2. Níveis de Proteção

A proteção deve ser proporcional à sensibilidade do dado:

- **Alta Sensibilidade:** Informações pessoais sensíveis (ex: saúde). Alto nível de controle.
- **Média/Baixa Sensibilidade:** Consequências da perda são menores. Nível de segurança adequado ao custo-benefício.

Admin / Execu-
tivo

Usuário Padrão

3. Responsabilidades

A política estabelece o que se espera de cada parte:

- **Usuários:** Usar senhas fortes, trancar salas, fazer log out.
- **Organização:** Prover ferramentas de backup, arquivamento e equipamentos seguros.

Compromisso Mútuo

A segurança só funciona se houver colaboração entre o técnico (org) e o humano (usuário).

4. Procedimentos e Tecnologias Legadas

- Por razões econômicas, pode ser necessário manter abordagens limitadas.
- **Exemplo:** Manter autenticação por senha em vez de biometria porque os usuários rejeitam mudanças complexas no fluxo de trabalho atual.

As políticas frequentemente estabelecem quem pode ler o quê:

- **Senioridade/Permissão:** O acesso é baseado na classificação do documento e na habilitação do leitor.
- **Regra:** Um leitor só pode acessar documentos de nível igual ou inferior ao seu.

Objetivo da Política

Garantir a conscientização organizacional sem ser um documento excessivamente técnico.

Classificação de Documentos

Ultrassegredo (Top Secret)
Segredo (Secret)
Confidencial
Aberto / Público



Sensibilidade
Crescente

- Focada em identificar e compreender os riscos para os ativos (sistemas e dados).
- **Dilema Prático:** Avaliar cada ativo individualmente pode ser inviável.

Sistemas Novos

Embora avaliações genéricas possam ser aplicadas a sistemas existentes, **sistemas novos** devem obrigatoriamente passar por avaliações de risco individuais.

Ataques de Personificação (Social Engineering)

Nem todos os ataques são técnicos. Alguns exploram falhas nos processos organizacionais:

- **Cenário:** Um atacante finge ser um engenheiro credenciado para ganhar acesso físico.
- **Defesa Simples:** Um processo organizacional de averiguação com fornecedores é mais eficaz do que qualquer barreira de software.

O Fator Humano

A tecnologia não pode deter alguém que "abre a porta" voluntariamente.

Estágio 1: Avaliação Preliminar de Risco

Ocorre antes das decisões detalhadas de projeto:

- Identificar riscos genéricos ao sistema.
- Avaliar se um nível de segurança adequado é alcançável por um custo razoável.
- **Resultado:** Auxilia na identificação dos **Requisitos de Segurança**.

Estágio 2: Avaliação de Risco do Projeto (Design)

Ocorre durante o ciclo de vida do desenvolvimento:

- Informada por decisões técnicas de projeto e implementação.
- Identifica vulnerabilidades conhecidas em middleware ou componentes reusáveis.
- **Resultado:** Pode levar à inclusão de novos requisitos técnicos e mudanças na funcionalidade.

Estágio 3: Avaliação de Risco Operacional

Focada no uso prático do sistema:

- Considera o ambiente real (ex: usuários saindo para resolver urgências).
- **Mecanismo de Defesa:** Implementação de *timeouts* para deslogar usuários inativos.

Natureza Contínua

A avaliação operacional deve continuar após a instalação para acompanhar a evolução do uso do sistema pela organização.

Requisitos de Segurança

Requisitos de Segurança da Informação (13.3)

A especificação de requisitos de segurança (security) tem muito em comum com a de segurança física (safety).

- **Natureza de Probabilidade:** Não é possível especificar nenhum dos dois como meras probabilidades.
- **Foco no Negativo:** Frequentemente são do tipo "**não deve**", definindo comportamentos inaceitáveis em vez de funcionalidades.

O Desafio

A segurança da informação é muito mais desafiadora do que a safety devido à presença de um adversário inteligente.

Especificação: Requisitos "Não Deve"

Requisitos Funcionais:

O que o sistema **deve** fazer.

Requisitos de

Segurança:

O que o sistema **não deve** permitir.

- Exemplo: "O sistema **não deve** permitir que usuários sem permissão 'X' acessem o registro 'Y'".

Segurança (Safety)

- **Ambiente:** Não hostil. Ninguém tenta causar incidentes ativamente.
- **Causa:** Erros acidentais ou omissões humanas.
- **Solução:** Buscar o erro no código ou processo.

Segurança da Informação

- **Ambiente:** Hostil. Ataques **deliberados** e planejados.
- **Causa:** Perpetrador inteligente explorando pontos fracos.
- **Dificuldade:** O atacante tenta esconder as provas.

- **Estratégia de Falha:**

- *Safety*: Desligar o sistema pode ser aceitável para evitar acidentes.
- *Security*: Desligar o sistema significa que o ataque de **Negação de Serviço** (DoS) foi bem-sucedido.

- **Dinâmica:**

- *Safety*: Eventos acidentais.
- *Security*: Adversário inteligente que sonda as defesas e modifica ataques conforme aprende.

10 Tipos de Requisitos de Segurança (Firesmith) I

Firesmith (2003) identificou 10 tipos fundamentais de requisitos:

Requisito	Definição
Identificação	O sistema deve identificar seus usuários antes da interação.
Autenticação	Especifica como os usuários são identificados (ex: tokens, biometria).
Autorização	Especifica privilégios e permissões de acesso.
Imunidade	Como o sistema se protege de vírus e worms.
Integridade	Como a corrupção de dados deve ser evitada.

10 Tipos de Requisitos de Segurança (Firesmith) II

Requisito	Definição
Detecção de Intrusão	Mecanismos para detectar ataques em tempo real.
Não repúdio	Uma parte não pode negar seu envolvimento em uma transação.
Privacidade	Como a privacidade dos dados deve ser mantida.
Auditoria	Como o uso do sistema pode ser auditado e verificado.
Segurança da Manutenção	Impedir que mudanças autorizadas quebrem a segurança.

- **Nota:** Nem todos os tipos são necessários em todos os sistemas.

Os requisitos de segurança apoiam três estratégias gerais:

- **1. Requisitos de Prevenção:** Evitar que os riscos surjam no projeto.
- **2. Requisitos de Detecção:** Identificar o risco e neutralizá-lo antes da perda.
- **3. Requisitos de Mitigação:** Projetar o sistema para recuperação e restauração após perda.

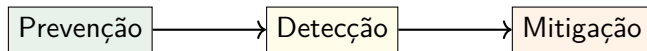
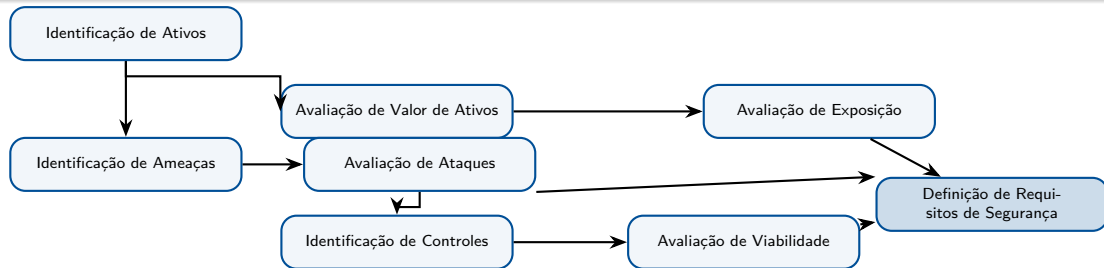


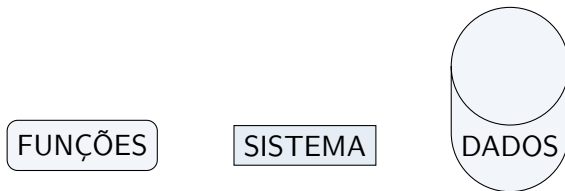
Figura 13.5: Processo preliminar de avaliação do risco

Identificação de ativos e ameaças para derivação de requisitos.



Estágio 1: Identificação de Ativos

- Identificar o que precisa de proteção no sistema.
- **O que pode ser um ativo?**
 - Dados associados ao sistema.
 - Funções específicas do sistema (ex: processamento de pagamentos).
 - O próprio hardware e infraestrutura.



- **Avaliação de Valor:** Quanto vale o ativo para a organização? (Financeiro, estratégico, reputacional).
- **Avaliação de Exposição:** Quais as perdas possíveis associadas a cada ativo?
 - Perdas diretas (furto de informação).
 - Custo da recuperação do sistema.
 - Danos à reputação da marca.

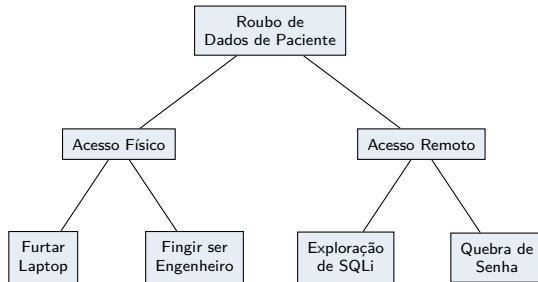
Estágio 4 e 5: Ameaças e Ataques

- **Identificação de Ameaças:** O que pode dar errado para cada ativo?
- **Avaliação de Ataques:** Decompor cada ameaça em ataques específicos.

Árvores de Ataque (Schneier)

Técnica para analisar como um ataque pode ocorrer, partindo da ameaça (raiz) e identificando as causas possíveis.

Exemplo de Árvore de Ataque

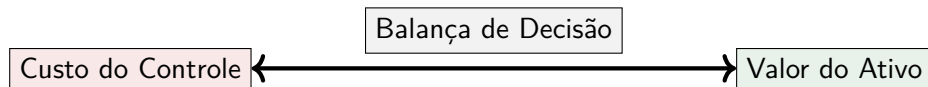


Estágio 6: Identificação de Controles

- Propor mecanismos técnicos ou organizacionais para proteger os ativos.
- **Mecanismos Técnicos:** Encriptação, firewalls, autenticação multifator.
- **Mecanismos Organizacionais:** Treinamento de pessoal, processos de auditoria.

Estágio 7: Avaliação de Viabilidade

- Avaliar a viabilidade técnica e os custos dos controles propostos.
- **Regra de Ouro:** Não vale a pena implementar controles cujo custo supere o valor do ativo ou a perda potencial.



Estágio 8: Definição de Requisitos

- Consolidação do conhecimento (exposição, ameaças e viabilidade) em requisitos formais.
- Os requisitos podem se aplicar à **infraestrutura** (ex: requisitos de rede) ou diretamente à **aplicação** (ex: lógica de autorização).

Conclusão

Um requisito de segurança bem definido é o fundamento para um sistema resiliente e confiável.

Obrigado!

Dúvidas?